

NIDS Projesi — Genel Sonuç Raporu

VAE ve Dense Autoencoder ile Anomali Tabanlı Saldırı Tespiti — Güncel Model (19 Feature, concurrency_src_1s Dahil)

Tarih: 30 Temmuz 2026 — Kapsam: proje kökü, 10_final_report/CHANGELOG.md'deki tüm ilgili maddeler

1. Giriş — Bu Proje Ne Yapıyor

Bu proje, bir laboratuvar ağında toplanan gerçek trafik akışlarından (Zeek *conn.log* kayıtları) yola çıkarak, **ağ saldırılarını normal (benign) trafikten ayırt eden** iki farklı unsupervised (etiketsiz-eğitim) anomali tespit modeli geliştiriyor: bir **VAE (Variational Autoencoder)** ve bir **Dense Autoencoder**. Her iki model de sadece normal trafikle eğitiliyor; model 'normal'in nasıl görüldüğünü öğreniyor, ve test zamanında bir flow'u kendi öğrendiği kalıba göre ne kadar kötü 'yeniden inşa edebildiğine' (reconstruction error) bakarak anormal (potansiyel saldırı) olup olmadığına karar veriyor.

Test edilen 3 saldırı tipi:

- **portscan** — hedef makinede açık port arayan, çok sayıda kısa/başarısız bağlantı üreten bir tarama aracı.
- **slowloris** — bağlantıyı olabildiğince uzun süre açık tutarak sunucu kaynaklarını tüketmeye çalışan bir DoS aracı.
- **apache_bench (ab)** — normalde bir performans/yük test aracı; burada saldırgan tarafından, sunucuyu yormak için aynı HTTP isteğini çok hızlı ve çok sayıda tekrarlamakta kullanılıyor.

Rapor boyunca geçen **threshold_95**, benign doğrulama (validation) akışlarının reconstruction-error dağılımının 95. persentilidir — 'benign trafiğin en kötü %5'inin üzerinde kalan her şey alarm' kuralı. Her metriğin tam tanımı ve neden seçildiği için bkz. *Metrikler_Aciklama_TR.pdf*.

2. Faz 1-2-3 — Veri, Feature'lar, Model (Kısa Özet)

Faz 1 — Veri Toplama

8 ayrı capture penceresinde (window_01_0pct ... window_08_22pct), benign ve saldırı trafiği eşzamanlı olarak toplandı; hedef saldırı yüzdeleri %0-22 arasında değişiyor. Toplama sırasında iki ciddi altyapı hatası (Zeek process restart'ı, ağ kartı checksum-offloading sorunu) tespit edilip düzeltildi ve etkilenen pencereler yeniden yakalandı — bozuk veri hiçbir analize girmedi.

Faz 2 — Feature Extraction ve Leakage-Free Split

Her flow'dan 18 modelleme feature'ı çıkarıldı: 8 ölçeklenmiş sayısal değer (süre, byte/paket sayıları, byte/paket oranları) ve 10 one-hot kategorik sütun (protokol, servis, bağlantı durumu). Train/val/test ayrımı, neredeyse-özdeş flow'ların (aynı araç, aynı parametrelerle üretilmiş) farklı split'lere sızmasını önlemek için **signature bazlı gruplama** ile yapıldı; ölçekleyici (StandardScaler) sadece train split'ine fit edildi — test/val bilgisi hiçbir zaman

ölçeklemeye karışmadı (leakage-free kural, proje boyunca korundu).

Faz 3 — Model Mimarisi ve Eğitim

Her iki model de aynı temel mimariyi paylaşıyor: *Input* → *Dense(16)* → *Dropout* → *Dense(8, bottleneck)* → *Dropout* → *Dense(16)* → *Output*. VAE'de bottleneck, bir ortalama/varyans (z_mean/z_log_var , latent boyut=10, $\beta=0.25$) çiftine dönüşüyor; Dense autoencoder'da bottleneck doğrudan 8 boyutlu bir sıkıştırma. Adam optimizer, MSE loss, en fazla 200 epoch, erken durdurma (patience=12). VAE, tamamen ayrı bir capture penceresinden (window_10, sadece benign, 3.049 flow) eğitildi; Dense ise windows 01-08'in train split'inden (23.274 flow, $\sim 7,6\times$ daha büyük) — bu eğitim-verisi farkı, iki modelin karşılaştırmasında hep akılda tutulması gereken bir not (bkz. bağımsız denetim bulgusu O5, aşağıda).

3. Bağımsız Denetim (Fable Review) — Özet

Proje, sonuçlar ilk kez raporlanmadan önce bağımsız bir teknik denetimden geçirildi (*11_fable_review/independent_audit.md*). Denetim 2 kritik (K1, K2) ve 7 orta düzey (O1-O7) bulgu tespit etti; hepsi ele alındı ve düzeltildi veya rapor metnine sınırlama notu olarak eklendi — hiçbirisi gözlerden kaçırılmadı.

Kod	Bulgu	Ne yapıldı
K1	Kontaminasyon sweep'inde benign ve attack farklı capture oturumlarından geliyordu — window-artefaktı ile saldırı etiketi birbirine karışabiliyordu (confound).	Deconfounded doğrulama kolu eklendi (11_deconfounded_check/); ana bulgular confound altında da geçerli çıktı.
K2	Benign train/val/test ayrımı düz rastgele permütasyonla yapılıyordu — Faz 2'nin signature-gruplama disiplini kontaminasyon sweep'inde uygulanmamıştı.	Signature-gruplu split ile yeniden doğrulama yapıldı.
O1	VAE'nin nominal latent boyutu (10), onu besleyen katmandan (8) geniş — mimari olarak tutarsız.	latent=8 ile ayrı bir ablasyon koşuturuldu: sonuçlar istatistiksel olarak ayırt edilemez çıktı (bkz. final rapor, latent-dimension notu).
O2	VAE anomali skoru tek stokastik örnekle (reparametrizasyon trick'i, sabit olmayan seed) hesaplanıyordu — sayılar çalıştırmadan çalıştırmaya değişebiliyordu.	Skorlama deterministik z_mean 'e geçirildi ($z = z_mean$, örnekleme yok); bu değişiklik concurrency_src_1s retrain'ine de (VAE v2) baştan uygulandı.
O3	Resampled pencereler (window_resampled_15/20pct) test setinde bazı flow'ların iki kopyasını barındırıyor — metrikler çift sayabiliyor.	Dedup sağlamlık kontrolü yapıldı (davranışsal metriklerde fark <0.02); bu düzeltme güncel (19-feature) PR-AUC/F1 sayılarına henüz yeniden uygulanmadı — bkz. Bölüm 6, açık sınırlama.
O4	Threshold_95 yöntemi (küçük val setinden %95 persentil) gürültülü ve val→test transferinde küçük bir sistematik sapma taşıyor.	Etki büyüklüğü ölçüldü ve rapora sınırlama notu olarak eklendi (bkz. final rapor).
O5	VAE-vs-Dense karşılaştırması, farklı eğitim verisi ve kapsamıyla confound'lu (mimari farkı mı, veri farkı mı belirsiz).	Rapor metinlerine bu confound'u açıkça belirten bir not eklendi.
O6	Segmented-injection'daki benign-segment FPR farkları 'örneklem gürültüsü' diye yorumlanmıştı; aslında window bazlı sistematik bir kompozisyon farkıydı.	Yorum düzeltildi; ana bulgu (apache_bench recall'unun blok halinde de düşük kalması) etkilenmedi.

Kod	Bulgu	Ne yapıldı
O7	Ground truth (is_attack) davranışa değil, kaynak IP kimliğine göre tanımlı — 'saldırgan makine' ile 'kötücül davranış' birebir örtüşmüyor.	Tehdit modeli sınırlaması olarak rapor metnine ve dokümantasyona eklendi.

(kaynak: 11_fable_review/independent_audit.md)

4. apache_bench Sorunu — Bulgu, Araştırma, Çözüm

4.1 Ne bulundu

Saldırı tipine göre kırılmış (ayrıştırılmış) performans ölçümü yapıldığında, toplu (agregat) metriğin gizlediği ciddi bir zayıflık ortaya çıktı: **apache_bench neredeyse hiç tespit edilmiyordu** (recall $\approx$ %2,6-3,3, ROC-AUC $\approx$ 0,58-0,70), portscan ve slowloris ise neredeyse kusursuzdu (recall $\geq$ %98,8). apache_bench, saldırı flow'larının yaklaşık yarısını oluşturdüğundan, bu zayıflık toplu metrikte kayboluyordu.

4.2 Neden kaçırılıyordu

apache_bench aynı kısa HTTP isteğini defalarca tekrarlıyor. Tek bir flow olarak bakıldığında bu istek sıradan, benign bir HTTP bağlantısından istatistiksel olarak ayırt edilemiyor — 18 feature'ın hiçbirisi flow'lar *arasındaki* ilişkiyi (tekrar hızı, eşzamanlılık) yakalamıyordu, hepsi tek bir flow'u kendi başına değerlendiriyordu.

4.3 Araştırma: bir başarısız, bir başarılı deneme

Önce denenen (başarısız): flow'lar-arası zaman farkı (IAT). *13_temporal_feature_experiment'*de, bir flow ile aynı kaynak IP'nin bir önceki flow'u arasındaki süre feature olarak eklenip modeller yeniden eğitildi. Sonuç: recall hiç değişmedi (KS istatistiği sadece 0,375 — mevcut feature'lardan zayıf). Bu deney ayrıca ilginç bir yan bulgu ortaya çıkardı: ilk teşhis analizindeki 'apache_bench medyan IAT'ı benign'den 2364x kısa' bulgusu, ölçümün seyrek bir test alt kümesinde yapılmasından kaynaklanan bir **artefakttı** — tüm flow'lar üzerinde doğru hesaplandığında fark sadece $\sim 2\times$ 'ye iniyordu.

Sonra denenen (başarılı): pencere-bazlı yoğunluk (concurrency). *14_concurrency_feature_experiment'*de, bir flow'un kendi zaman damgası etrafında (± 1 saniye) aynı kaynak IP'den kaç flow daha geldiği sayıldı (**concurrency_src_1s**). Bu feature apache_bench'i güçlü şekilde ayırt etti ve retrain sonrası recall'u kalıcı olarak yükseltti. Knock-out testi (feature'ı dondurup modeli aynen değerlendirme) iyileşmenin gerçekten bu feature'dan geldiğini doğruladı.

4.4 Canonical modele entegrasyon — 3 aşamalı retrain

- **Aşama 1 — Dense v2:** concurrency_src_1s, Dense pipeline'ının feature tablosuna eklendi (log1p + sadece benign-train'e fit StandardScaler, leakage-free); Dense autoencoder 5 seed ile 19-feature üzerinde yeniden eğitildi.
- **Aşama 2 — VAE v2:** aynı feature, VAE'nin tamamen ayrı eğitim verisi kaynağı olan window_10 için de (Dense v2'nin AYNI scaler'ıyla, refit edilmeden — assert ile doğrulandı) hesaplandı; VAE 5 seed ile 19-feature üzerinde, deterministik z_mean skorlamayla yeniden eğitildi.
- **Aşama 3 — Pairwise + Segmented:** her iki yeni model, ikili kombinasyon ve bloklü-enjeksiyon protokolleriyle de değerlendirildi.

Sonrasında eski (18-feature) tüm sonuçlar *V1_ARCHIVE'*a taşındı (silinmedi) ve 19-feature sonuçlar tek canonical sürüm oldu.

(kaynak: *10_final_report/CHANGELOG.md*, 2026-07-30 tarihli maddeler; *V1_ARCHIVE/README.md*)

5. Güncel (v2) Sonuçlar — Her İki Model

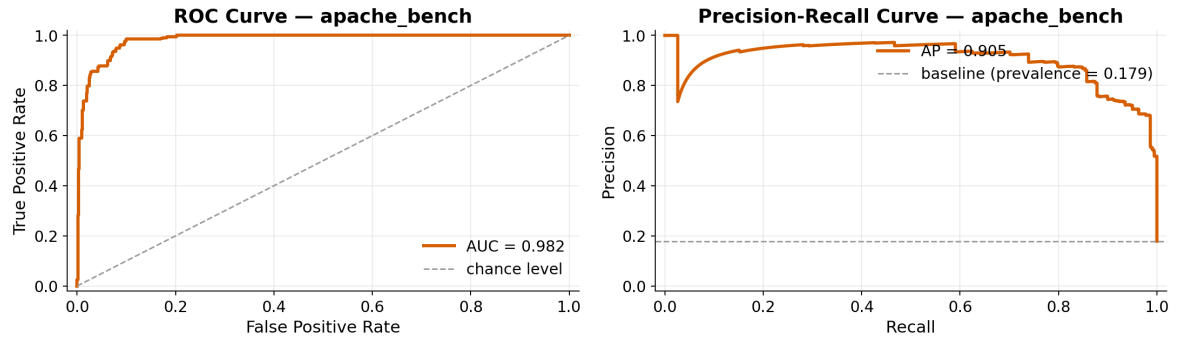
Aşağıdaki tüm sonuçlar canonical modele aittir: 19 feature (concurrency_src_1s dahil), 5 seed, threshold_95 seed başına yeniden hesaplanmış. **Pooled recall**, bir ikili (pair) değerlendirme setindeki TÜM saldırı flow'larının ortalama recall'udur; **decomposed recall** ise aynı setin içindeki tek bir saldırı tipinin (örn. sadece apache_bench) kendi recall'udur — ayırım Bölüm 5.2'de somut sayılarla gösteriliyor.

5.1 Tekli saldırı tipi (single attack-type)

Model	Saldırı tipi	ROC-AUC	PR-AUC	F1	Benign FPR	Recall
Dense	apache_bench	0,9808 ± 0,0076	0,8930	0,8218	0,0660 ± 0,0036	0,9092 ± 0,0382
Dense	portscan	0,9997 ± 0,0002	0,9973	0,7551	0,0660 ± 0,0036	1,0000 ± 0,0000
Dense	slowloris	1,0000 ± 0,0000	1,0000	0,8050	0,0660 ± 0,0036	1,0000 ± 0,0000
VAE	apache_bench	0,9836 ± 0,0123	0,9035 ± 0,0805	0,8428 ± 0,0337	0,0664 ± 0,0110	0,9500 ± 0,0453
VAE	portscan	0,9998 ± 0,0001	0,9983	0,7551	0,0664 ± 0,0110	1,0000 ± 0,0000
VAE	slowloris	1,0000 ± 0,0000	1,0000	0,8048	0,0664 ± 0,0110	1,0000 ± 0,0000

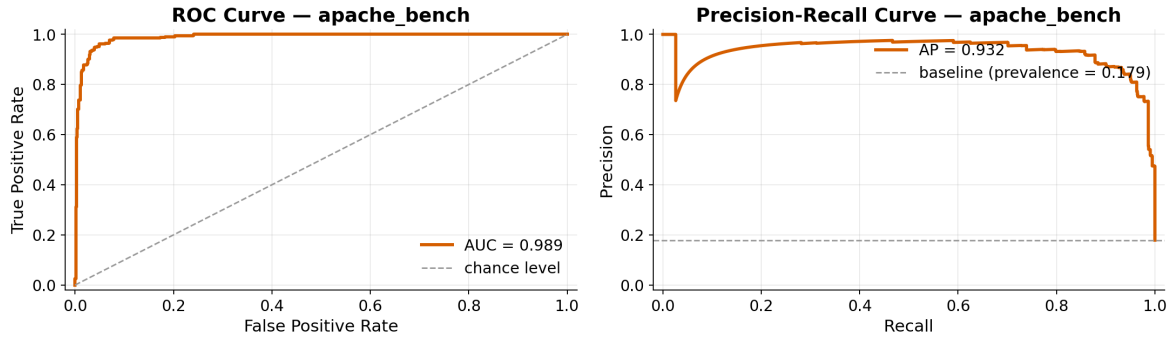
(kaynak: 09_dense_v2_comparison/results_single_attack_type_dense_v2.csv/.md, 10_vae_v2_comparison/results_single_attack_type_vae_v2.csv/.md)

Dense autoencoder (full_features + concurrency_src_1s)
vs. benign — apache_bench — n_attack=1487, n_benign=6821



Şekil 1 — Dense autoencoder, apache_bench için ROC ve Precision-Recall eğrileri.

VAE (contam_0pct, 19 features: +concurrency_src_1s, deterministic z_mean)
vs. benign — apache_bench — n_attack=1487, n_benign=6821



Şekil 2 — VAE, apache_bench için ROC ve Precision-Recall eğrileri.

5.2 İkili kombinasyonlar (pairwise)

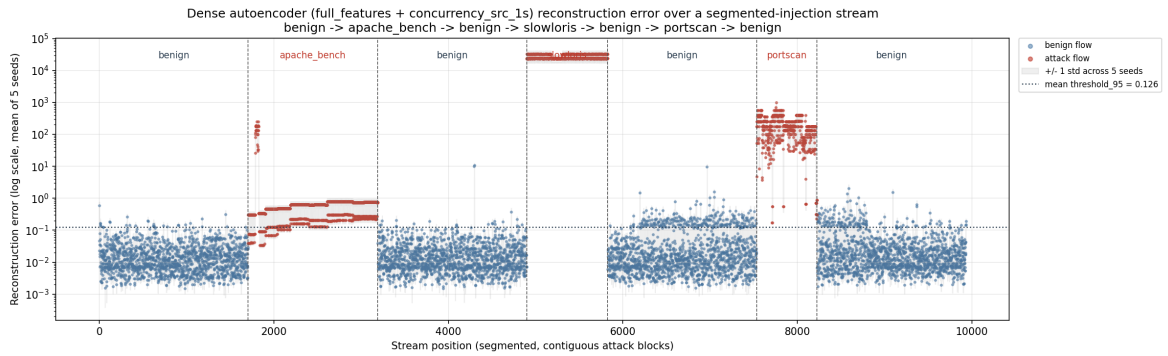
Model	Çift	ROC-AUC	Pooled Recall	apache_bench-only Recall (decomposed)
Dense	portscan + apache_bench	0,9868 ± 0,0052	0,9381 ± 0,0261	0,9092 ± 0,0382
Dense	apache_bench + slowloris	0,9882 ± 0,0046	0,9441 ± 0,0235	0,9092 ± 0,0382
VAE	portscan + apache_bench	0,9887 ± 0,0084	0,9659 ± 0,0309	0,9500 ± 0,0453
VAE	apache_bench + slowloris	0,9899 ± 0,0076	0,9692 ± 0,0279	0,9500 ± 0,0453

apache_bench'in kendi (decomposed) recall'u, hangi diğer saldırı tipiyle eşleştirildiğinden bağımsız olarak **sabit** kalıyor (Dense: her koşulda 0,9092; VAE: her koşulda 0,9500) — pooled recall'daki artış, sadece daha iyi tespit edilen bir tipin karışıma eklenmesinden kaynaklanan bir karışım etkisi, apache_bench'in kendi tespitinde bir iyileşme değil.

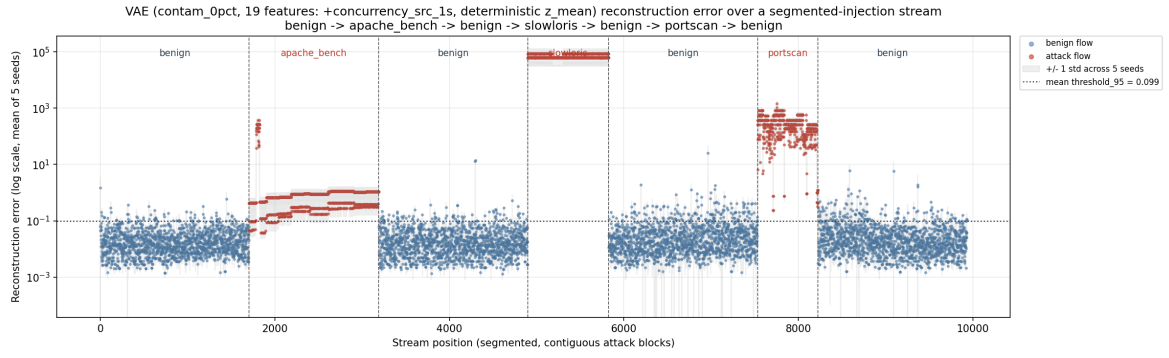
(kaynak: 11_pairwise_segmented_v2/{dense_v2,vae}/results.md)

5.3 Bloklı (segmented) enjeksiyon

Aynı test flow'ları, karışık sırada değil, bitişik bloklar halinde yeniden sıralandı: benign → apache_bench → benign → slowloris → benign → portscan → benign. Amaç: saldırı tipi izole bir blok halinde gelse bile modelin davranışının değişip değişmediğini kontrol etmek.



Şekil 3 — Dense autoencoder, bloklı enjeksiyon akışı boyunca reconstruction error (log ölçek, 5 seed ortalaması). threshold_95 = 0,1256.

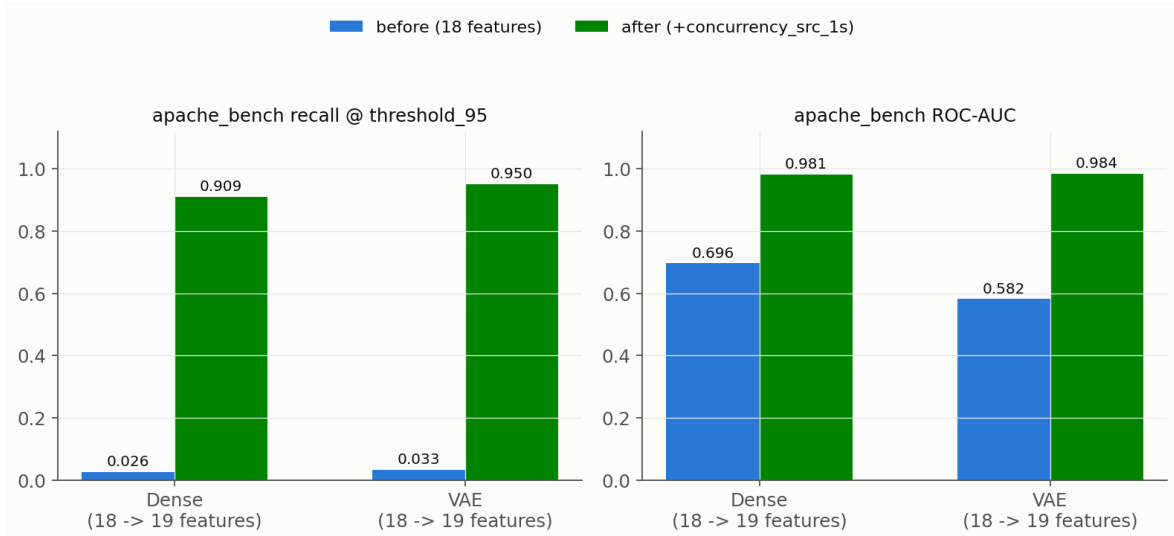


Şekil 4 — VAE, aynı akış. $\text{threshold}_{95} = 0,0987$.

Her iki modelde de blok-recall, karışık test setindeki recall'la birebir aynı çıktı (Dense apache_bench bloğu: 0,9092; VAE: 0,9500) — modelin her flow için verdiği karar, o flow'un akışta nerede durduğundan bağımsız, statik bir karar.

(kaynak: 11_pairwise_segmented_v2/{dense_v2,vae}/block_recall_f1.md)

5.4 Özet: değişimin büyüklüğü



Şekil 5 — apache_bench recall ve ROC-AUC, eski (18 feature) ve yeni (19 feature, concurrency_src_1s dahil) model, her iki mimari.

6. Açık Sınırlama Notu

O3 dedup-prevalence düzeltmesi, güncel (19-feature) PR-AUC/F1 sayılarına henüz yeniden uygulanmadı. Eski (18-feature) rapor, resampled pencerelerin (window_resampled_15pct/20pct) test setinde bazı gerçek flow'ları iki kez saydığını tespit edip (bağımsız denetim bulgusu O3), PR-AUC/F1'i dedup edilmiş bir test setinden yeniden hesaplayan bir düzeltme uygulamıştı — ROC-AUC/recall/FPR gibi davranışsal metriklerin bu çift-saymadan etkilenmediği ayrıca doğrulanmıştı (fark $<0,02$). Bu düzeltme, concurrency_src_1s entegrasyonu sonrası güncel modele **henüz yeniden uygulanmadı** — bu raporda gösterilen ROC-AUC, recall ve FPR sayıları güvenilir kabul edilebilir, ancak PR-AUC ve F1 sayıları düzeltme uygulanana kadar **geçici (provisional)** olarak okunmalı. Bu, bilinen ve takip edilen bir sonraki adım, sessizce göz ardı edilmiş bir hata değil.

(kaynak: V1_ARCHIVE/10_final_report/01_single_attack_type/vae/dedup_sanity_check/
10_final_report/07_final_written_report/rapport_final_attack_type_analysis.md, Bölüm 6)